

MT17 · Tokens funcionals del backend

Un token funcional és un permís puntual i limitat per a una operació concreta del domini. No és OAuth, no és JWT professional: és una eina senzilla, controlada i lligada a un cas real del teu projecte.

R4S6 · DAW

60 MIN



Idea central: permís puntual i limitat

Un token funcional **no és un login**. És una cadena opaca que autoritza *una sola acció* sobre un recurs concret, durant un temps limitat.

 Exemple: un codi d'un sol ús per confirmar una reserva o cancel·lar una cita sense necessitat d'autenticar-se de nou.

Limitat en abast

Autoritza exactament una operació, no tot el compte.

Limitat en temps

Caduca. Sense caducitat no és un token funcional vàlid.

Lligat al domini

Associat a una entitat concreta: reserva, cita, incidència...



Casos d'ús reals

On apareixen tokens funcionals al backend del teu domini?



Confirmar reserva

L'usuari rep un token per correu i el clica per confirmar la seva cita o reserva.



Cancel·lar cita

Un token d'un sol ús permet cancel·lar sense accedir al panell d'usuari.



Acceptar invitació

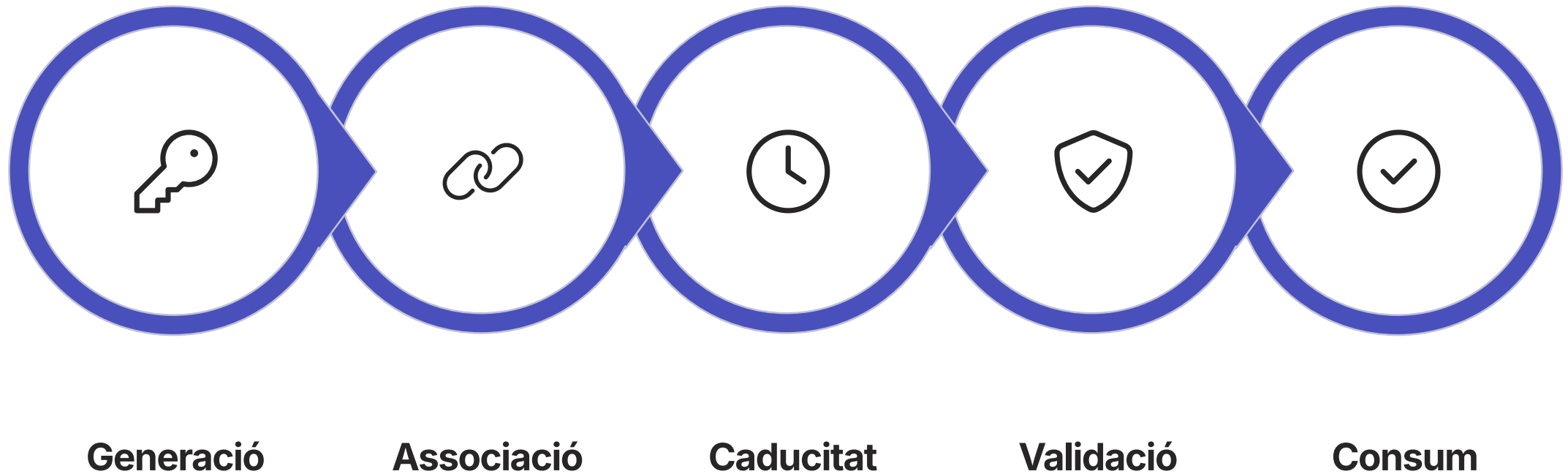
Un token associa la invitació a un compte nou o existent en el moment d'acceptar.



Validar entrega

El repartidor utilitza un token per marcar l'entrega com a completada al sistema.

Cicle de vida del token



Cada fase és obligatòria. Un token sense **caducitat** o sense **consum registrat** és un risc de seguretat i no compleix els requisits mínims del repte.



Errors habituals

✗ Sense caducitat

Un token que no expira pot ser reutilitzat indefinidament. Sempre defineix un TTL.

✗ Massa permisos

Si el token dóna accés a més d'una operació, ja no és funcional: és una sessió encobertes.

✗ Consum no registrat

Si no marques el token com a consumit, es pot usar múltiples vegades.

✗ Confondre'l amb login

El token funcional no autentica la persona: autoritza una acció concreta i prou.

Evidència del dia i tancament

Què has d'entregar per a R4S6

01

Flux tokenitzat documentat

Diagrama o descripció de tot el cicle al teu projecte.

02

Cas vàlid demostrat

Token correcte, dins el temps, no consumit: operació executada.

03

Cas invàlid o caducat

Token expirat o ja usat: el sistema ha de rebutjar-lo amb error clar.

04

Decisió d'ús únic o revocació

Justifica si el token s'elimina en consumir-se o si es pot revocar manualment.

Pregunta de tancament

Què podria fer una persona malintencionada si intercepta aquest token?
Quant de temps tendria per actuar? Podria usar-lo dues vegades?

Respondre aquestes preguntes és el mínim de seguretat exigible a qualsevol token funcional del teu domini.



Si el teu token caduca, s'associa a un recurs i es marca com a consumit, estàs en el bon camí. 